

《Linux 系统安全管理及开发》实验报告

实验名称：

实验九 案例项目的安全管理改进

团队名称：

学生姓名（班级、学号）：

指导教师：

韦勇

实验时间：

2024 年 12 月 17 日下午

1. 需求分析

（所选取的多个开发任务的描述）

1.1) 需要解决的问题

Linux 项目中使用弱密码会导致系统易受攻击，增加数据泄露和未授权访问的风险。攻击者可能利用简单密码破解账户，造成数据丢失、服务中断和法律合规问题，给项目带来严重的安全威胁和潜在的经济损失。我们打算添加教师和学生创建账号时设置密码时禁止弱密码的功能，以及完善一下其他模块的功能，以保障项目的完整性与安全性。

1.2) 具体描述

学生端：

- 解决学生注册账号时不能注册密码的缺陷，并添加禁止弱口令的功能
- 添加学生端更改密码时禁止弱口令的功能

教师端：

- 补充一下教师注册账号时的弱密码判断功能。
- 解决教师无法更改密码的问题，并添加禁止弱口令的功能

1.3) 解决方案

学生端：

1、先查看服务器端程序分析，可以知道，要添加相关功能，可以从 `server.bash` 和 `server.lib` 文件入手，修改里面的代码来实现相关功能，找到 `server.bash` 文件，看到 `server` 菜单处，发现注册学生账号使用的 `register` 函数。在 `server.lib` 中找到注册（`register`）函数查看对应代码，发现[]与变量之间没有空格，会导致系统无法识别变量导致的报错，进行修改，修改完后实现了学生端注册密码及禁止弱口令功能。

2、登陆学生账号报错 `su:Authentication failure`，使用 `cat /etc/shadow` 查看账号信息，发现账号处于!! 状态，一般是未设置密码的意思，说明密码未写入改文件，查看学生注册函数 `register`。发现使用系统命令 `passwd` 时，没有授予 `sudo` 权限，导致密码写入失败。重新创建学生账号登陆，发现即可登陆成功进行密码修改，且修改学生密码具有防止弱密码功能。

教师端：

1、我们找到教师修改密码的函数（前面的主菜单函数处）`RegisterTeacherAccount()`，并添加与 `Register` 函数对应的代码，添加后使用教师注册功能，实现了教师端注册密码时禁止弱口令的功能。

- 2、查看教师修改密码的代码，可以看到修改密码的函数为 `ChangeAccountPasswd()`，可以发现会先判断教师账号是否在 `GetAllTeacherAccount` 函数中，在界面查看所有教师账号，发现为空，也就是说，无法更改教师密码的问题出在 `GetAllTeacherAccount` 函数没有教师账号中，查看 `GetAllTeacherAccount` 函数，可以发现里面出现了一个文件地址 `/etc/group`，查看 `/etc/group` 文件，发现有信息，但是没有 `sudo` 权限的用户信息，把函数中有关 `sudo` 权限的信息改为提取 `teacher` 后的用户信息。修改以后解决教师无法更改密码的问题，并添加禁止弱口令的功能。

1.4) 评价方法

教师和学生使用注册账号密码和更改账号密码的过程中，首先要有注册和修改密码的功能，其次输入弱口令，系统会有禁止弱口令的字样，并且让用户重新输入口令，这样就可以达到我们的预想。

2. 开发计划

2.1) 开发任务

1. 完成学生端无法在注册账号后设置密码的功能，以及对密码的禁止弱口令功能
2. 在教师端原有的设置密码功能上加入禁止弱口令功能

2.2) 开发分工

2.3) 开发进度

口令强度检查功能					
序号	任务	第1-2天	第3-5天	第6天	第7-8天
1	需求分析和流程设计	100%			
2	编写代码及运行调试程序		100%		
3	测试项目功能并推送			100%	
4	编写PPT及文档				50%

2.4) 关键问题

1. 在实现学生注册账号的具体代码即 `register()` 函数中，发现中括号 `[]` 与变量之间没有空格，导致变量无法被识别从而报错
2. 设置好密码后再进行登录，发现系统提示账号依旧处于未设置密码的状态，说明刚才设置的密码并没有生效即未写入管理密码的文件中，所以再次打开刚才的函数代码，发现在使用 `passwd` 命令设置密码时并没有赋予其 `sudo` 权限，这就会导致密码无法被写入指定文件也就不会生效
3. 在为教师端设置禁止弱口令功能时，只需要将学生端注册账号的 `register()` 函数中的相应实现该功能的代码运用进来
4. 在教师端进行修改密码时，会提示账号不存在，去查看对应的函数 `ChangeAccountPasswd()`，检查其中的代码发现是判断教师账号是否存在这个函

数 GetAllTeacherAccount () 出错了，再次查看其代码发现查找的字符串不对，应该是查找有关 “teachers” 字符串的，而不是 sudo

3. 设计与实现

3.1) 总体设计

学生端：注册账号后设置密码时禁止弱密码的功能，并且可以登录进去修改密码

教师端：设置密码时禁止弱密钥，并且可以登录教师账号对密码进行修改

3.2) 开发过程

先对服务器端程序分析，要添加相关功能，可以从 server.bash 和 server.lib 文件入手，修改里面的代码来实现相关功能

服务器端程序分析		
文件名	路径	作用
server.bash	bin/server.bash	启动服务器端主菜单
server-students.bash	bin/server-students.bash	启动服务器端学生功能菜单
server-teachers.bash	bin/server-teachers.bash	启动服务器端教师功能菜单
server.lib	lib/server.lib	服务器端程序的函数定义
server.conf	etc/server.conf	服务器端程序配置文件
linuxer	etc/sudoers.d/linuxer	服务器端sudoer功能配置文件

3.3) 代码分析

- 学生端注册密码和禁止弱口令功能：

在 server.lib 中找到注册（register）函数

```

64 #注册函数
65 register()
66 {
67     #RETURN 初始赋值为1
68     RETURN=1
69
70     #新建学生组
71     sudo groupadd $STUDENT_GROUP > /dev/null 2>&1 #make sure group is created before
72
73     while [ $RETURN != 0 ]
74     do
75         #输入ID
76         read -p "Your student ID (e.x. $STUDENT_ID)[ 0 means quit ]:" ID
77         #如果输入0则退出
78         if [ ${ID:-0} == 0 ]; then
79             exit
80         fi
81
82         #判断输入合法性
83         if [[ ! $ID =~ $STUDENT_PATTERN ]] || [ ${#ID} != ${#STUDENT_ID} ]; then
84             echo "The account you chosen is invalid, please try again!"
85             continue
86         fi
87
88         #检查是否存在已经注册的相同账号
89         grep $ID /etc/passwd > /dev/null 2>&1
90         #如果存在已经注册的相同账号
91         if [ $? == 0 ]; then
92             echo "The ID you input have already been created, please contact the teacher!"
93             read
94             exit
95         fi
96         #添加该学号用户
97         sudo useradd -s /opt/linuxer/bin/server-students.bash -m $STUDENT_GROUP -m $ID > /dev/null
98         logger -it server.lib add student user $ID!
99         #上一条命令执行状态赋值给RETURN
100         RETURN=$?
101         #如果用户添加失败
102         if [ $RETURN != 0 ]; then
103             echo "The account you chosen cannot been created, please contact your
104             administrator!"
105             exit
106         fi
107     done
108     #拦截终止程序型号量，防止用户终止程序
109     trap "userdel -r $ID; trap - SIGINT SIGTERM" 0
110     echo "Set password for your account:"

```



提交的代码请注意增加函数注释，其中包含小组信息。



在合适位置添加调试语句，注释掉清屏查看，发现 line115 报错

```

Your student ID (e.x. 5120180001)[ 0 means quit ]:5120180003
Set password for your account:
/opt/linuxer/lib/server.lib: line 115: [0: command not found

```

应该将划线处的变量（含\$符）和中括号之间用空格隔开，不然 shell 无法将其识别为一个变量，同时还会报错，修改完毕后，学生端实现了注册密码和禁止弱口令的功能。

```

max_attempts=3
attempts=0
while [ $attempts -lt $max_attempts ]; do
    read -s -p "Set password:" password
    echo
    if [ ["$password" =~ [A-Z] && "$password" =~ [a-z] && "$password" =~ [0-9] ] ]
    (echo -e "$password\n$password" | passwd $ID > /dev/null 2>&1)
    echo "succeed"
    break
    else
    echo "fiald"
    echo "Set password:"
    attempts=$((attempts + 1))
    if [ $attempts -lt $max_attempts ]; then
        echo "Remaining times: $((max_attempts - attempts))"
    else
        echo "too many errors"
    fi
done

```

当前系统用户

- 学生端更改密码及禁止弱口令功能：

登陆学生账号报错 su:Authentication faliure, 使用 cat /etc/shadow 查看账号信息, 发现账号处于!! 状态, 一般是未设置密码的意思。

```

5120180001:$6$9e0/I4hh$0jrvJswp/hxgG8Iai/q9tK3szqoaYJ8SB6qLRJg90i
v.cs3apMULqfe0.fsdn/GbbJEBGC.x28QsIczPClZH40:18863:0:99999:7:::
5120180002:$6$l8RIwtm/$2zN4W6.MyVUk0g8RpcFx9ABzuFpdtCH51NzIsuSABb
8otMmT0dXX98dLcG50Dbm4zQUsqpz7LAKvLvY/F8AEY/:20069:0:99999:7:::
5120180003:!!!20069:0:99999:7:::
5120180004:!!!20069:0:99999:7:::
5120180005:!!!20069:0:99999:7:::

```

说明密码未写入改文件, 查看学生注册函数 register。

```

max_attempts=3
attempts=0
while [ $attempts -lt $max_attempts ]; do
    read -s -p "Set password:" password
    echo
    if [ ["$password" =~ [A-Z] && "$password" =~ [a-z] && "$password" =~ [0-9] ] ]
    (echo -e "$password\n$password" | passwd $ID > /dev/null 2>&1)
    echo "succeed"
    break
    else
    echo "fiald"
    echo "Set password:"
    fi
done

```

(echo -e "\$password\n\$password" | **sudo** passwd \$ID > /dev/null 2>&1)

要使用 sudo 权限才能将密码写入指定文件, 否则密码不会被记录, 修改后重新创建学生账号登陆, 发现即可登陆成功进行密码修改, 且修改学生密码具有防止弱密码功能。

```

Please input your choice:
1
Changing password for user 5120180006.
Changing password for 5120180006.
(current) UNIX password:
New password:
BAD PASSWORD: The password is a palindrome
New password:
BAD PASSWORD: The password is the same as the old one
passwd: Have exhausted maximum number of retries for service
New password:
BAD PASSWORD: The password fails the dictionary check - it is too
simplicitic/systematic

```

- 添加教师端注册密码时禁止弱口令功能：

我们找到教师修改密码的函数（前面的主菜单函数处）RegisterTeacherAccount(),

```

#拦截终止程序型号量，防止用户终止程序
trap "userdel -r $ID; trap - SIGINT SIGTERM; stty echo; exit" SIGINT SIGTERM
echo "Set password for your account:"
#如果用户没有设置密码
if ! sudo passwd $ID; then
    #删除该用户
    sudo userdel -r $ID
fi

```

并添加与 Register 函数对应的代码：

```

#拦截终止程序型号量，防止用户终止程序
trap "userdel -r $ID; trap - SIGINT SIGTERM; stty echo; exit" SIGINT SIGTERM

max_attempts=3
attempts=0
while [ $attempts -lt $max_attempts ]; do
    read -s -p "Set password: " password
    echo
    if [ [ "$password" =~ [A-Z] && "$password" =~ [a-z] && "$password" =~ [0-9] && ${#password} -gt 8 ] ]; then
        echo -e "$password\n$password" | sudo passwd $ID > /dev/null 2>&1
        if [ $? -eq 0 ]; then
            echo "Success"
            exit 0
        else
            echo "Failed"
            echo "Set password:"
            attempts=$((attempts + 1))
        fi
    fi
done

```

添加后使用教师注册功能，先使用弱口令 123456789 测试一下，可以看到创建失败

```

Set password: (密码至少包含一个大写字母，一个小写字母以及数字，长度大于8)
failed
Set password:
Remaining times: 2
Set password: (密码至少包含一个大写字母，一个小写字母以及数字，长度大于8)

```

输入 Csi123456，可以发现创建成功，这样我们就实现了教师端注册密码时禁止弱口令的功能


```
=====
Congratulation! Your account 1020170002 is Create.
But your account has been locked.
please contact the teacher-manager to unlock.
Then you can login in using your account 1020170002.
=====
```

- 添加教师端修改密码及禁止弱口令功能

查看教师端修改密码部分的代码，可以看到修改密码的函数为 ChangeAccountPasswd()

```
read -p "Please input your choice:" VCHOICE
if [ -z $VCHOICE ];then
    VCHOICE=0
fi
case $VCHOICE in
    #查看所有账号
    1) GetAllTeacherAccount;;
    #查看被锁账号
    2) GetLockAccount;;
    #查看未锁账号
    3) GetUnlockAccount;;
    #教师账号加锁
    4) LockAccount;;
    #教师账号解锁
    5) UnlockAccount;;
    #教师账号删除
    6) DeleteAccount;;
    #教师账号修改密码
    7) ChangeAccountPasswd;;
    #增加教师账号
    8) RegisterTeacherAccount&&MenuWord;;
    9)if [ "$LANGUAGE" == "en_US" ]; then
```

找到这个函数 ChangeAccountPasswd(), 可以发现会先判断教师账号是否在 GetAllTeacherAccount 函数中

```
#教师账号改密码
ChangeAccountPasswd()
{
    while true
    do
        read -p "Please input the account you want to change passwd(0 to quite!):" Caccount
        if [ -z $Caccount ] || [ $Caccount == 0 ]; then
            return
        fi

        Accounts=$(GetAllTeacherAccount)
        have=1
        for i in $Accounts; do
            if [ $i == $Caccount ]; then
                have=0
                sudo passwd $Caccount
                logger -it server.lib change teacher account pwd $Caccount!
                echo "Change Successfully!"
                break
            fi
        done
        if [ $have == 1 ];then
            echo "Account does not exist!"
        fi
    done
}
```


返回输入 1，查看所有教师账号，发现为空，也就是说，无法更改教师密码的问题出在 GetAllTeacherAccount 函数没有教师账号中

```
查看管理员账户功能
主菜单
1 查看所有教师账号
2 查看锁定的教师账号
3 查看未锁定的教师账号
4 锁定教师账号
5 解锁教师账号
6 注销教师账号
7 修改教师账号密码
8 注册教师账号
9 Switch language(切换语言)
0 返回

Please input your choice:1
Please input your choice:0
```

查看 GetAllTeacherAccount 函数，可以发现里面出现了一个文件地址，红线标注处就是实现禁止弱密码功能的核心部分，意思是密码必须至少要包含一个大写字母、一个小写字母、一个数字，并且长度大于 8 个字符否则不合法，如果这些条件都满足，脚本会尝试使用 `sudo passwd $ID` 命令来设置密码

```
#获取所有教师账号
GetAllTeacherAccount()
{
    sudo grep sudo /etc/group | awk -F ':' '{print $4}' | tr ',' ' '
```

grep 用于在文件中搜索匹配的字符串，要搜索账号就应该将 sudo 改为 teachers，去搜索教师的账号

```
#获取所有教师账号
GetAllTeacherAccount()
{
    sudo grep '^teachers:' /etc/group | awk -F ':' '{print $4}' | tr ',' ' '
```

修改完以后，教师可以更改密码并且更改密码时会有禁止弱口令的功能。

3.4) 使用手册

```
这是Linuxer服务端.(版本号:V4.0)
主菜单
1 注册账号(学生)
2 注册账号(教师)
3 其他功能
4 Switch language(切换语言)
0 返回
请输入你的选择
```

登录进 linuxer 服务端，输入 1 注册学生账号，设置密码时会禁止弱口令，即不可以设置太过于简单的密码，输入 2 注册教师账号，具有与学生端相同的禁止弱口令功能。

```
MENU
1 View teacher account
2 Lock teacher account
3 Unlock teacher account
4 Delete teacher account
5 Teacher account change password
6 Register teacher account
7 Change passwd
8 List scores
9 Mark reports
10 Switch language(切换语言)
a System admin
b group_students
c query_groups
d query_all_student_groups
e query_student_group
f Statistical results
g average score
  h Grade warnning
0 return
Please input your choice:
```

再登录教师账号时，可以修改账号的密码

4. 开发总结

4.1) 实际结果

我们最终解决学生注册账号时不能注册密码的缺陷，并添加禁止弱口令的功能；解决学生端更改密码时禁止弱口令的功能；补充一下教师注册账号时的弱密码判断功能；解决教师无法更改密码的问题，并添加禁止弱口令的功能。

4.2) 工作评价

我们在这次实验中还是遇到了一些问题，其实我们刚开始是想实现一个口令强度检查的功能，在撰写和修改代码之前，我们测试了原项目的一些功能，发现源代码的一些基础功能还不全，比如说学生端注册时没有注册密码的选项，教师端无法更改密码，所以我们的项目方案只能更改为先补全基础性能，再来实现口令强度检查功能。随着项目的推进，我们发现那些缺少功能中的代码很多是没有问题的，只是在格式中出现了一些谬误，比如学生端注册密码的代码并不是没有，而是格式错误，[]与变量之间没有空格，会导致系统无法识别变量导致的报错。只需简单修改，学生端就具有了注册密码和禁止弱密码的功能，猜测这段代码可能是以前的同学留下的。于是我们舍弃了口令强度检查这个方案，采用了禁止弱口令的方案，毕竟检查弱口令强度的最终目的不是让用户舍弃弱口令，设置强口令吗？同理，在教师端的修改密码的地方也有这种小细节的问题，只需把 GetAllTeacherAccount 函数中的 sudo 改成 teacher，这样更改密码和禁止弱口令的功能就都实现了。

在这次的项目中，我们组每个成员都积极参与，可以说，这个项目的功能离不开我们整个团队的贡献。

4.3) 经验与教训

在本次 Linux 项目的开发中，我们小组集中精力提升了系统安全性，特别是在用户密码管理方面。我们修复了学生注册时无法设置密码的问题，并加入了禁止弱口令的功能，增强了账户安全性。同时，我们为学生端的密码更改过程增加了弱口令检测，进一步保障了安全，同时我们也明白了细节决定成败。

对于教师端，我们不仅补充了注册时的弱密码判断，还解决了更改密码的问题，并同样加入了禁止弱口令的功能。这些改进体现了我们对安全性的重视和在开发中实施最佳实践的能力。

在开发过程中，我们创建了新的分支进行开发，这有助于保持主分支的稳定性，并便于后续的代码审查和合并。通过使用 Git 进行版本控制，我们能够顺利地将本地的更改提交并推送到远程仓库，与团队成员共享我们的工作成果。这一过程不仅提高了我们的开发效率，也加强了团队之间的协作。

通过这次项目，我们小组不仅提升了自己的编程技能，还加深了对 Linux 系统和网络安全的理解。我们学会了如何在实际开发中应用密码安全的最佳实践，以及如何使用 Git 进行有效的版本控制和团队协作。此外，我们也意识到了在软件开发中，持续集成和持续部署（CI/CD）的重要性，这将有助于我们在未来的项目中提高开发效率和代码质量。

如果说项目功能有什么没有完善的地方，那就是在“禁止弱口令”方面不够多样化，如果有机会的话，我们还想增加口令强度打分功能，让界面看起来更加多样化。

总的来说，这次项目经历对我们小组来说是一次宝贵的学习机会，它不仅

让我们在技术层面上有所成长,也让我们在团队合作和项目管理方面有了更深的认识。我们期待将这些经验和知识应用到未来的工作中,为更多的项目带来价值。